

Contents

The Agent Identity Framework	1
Composable Accountability for AI Agents in the Digital Economy	1
Abstract	1
1. Introduction	2
2. Design principles	3
3. Architecture	3
4. Identity: behavior commitments, not model hashes	4
5. Authority: a capability algebra	5
6. The Action Envelope	5
7. Reversibility as a structured descriptor	6
8. The Accountability Escrow	7
9. Receipts and transparency	7
10. Credentials and issuer market structure	8
11. Liability allocation	9
12. Conformance levels	9
13. Integration with the existing ecosystem	10
14. Illustrative use cases	11
15. Threat model	11
16. Open research questions	12
17. Related work	13
18. Conclusion	14
References and further reading	14

The Agent Identity Framework

Composable Accountability for AI Agents in the Digital Economy

Author: William Wei — <https://www.linkedin.com/in/williamwei> **Version:** 1.0 (public draft)
Date: April 2026

Abstract

AI agents are beginning to place orders, sign contracts, commit code, vote in governance, and move money on behalf of people and organizations. The internet’s identity, authorization, and accountability primitives were designed for human principals operating behind OAuth and card networks, and they do not extend cleanly to autonomous software that acts, delegates, copies itself, and upgrades continuously. This paper proposes the **Agent Identity Framework (AIF)**: a composable accountability layer that sits between the identity plane (decentralized identifiers, verifiable credentials) and the settlement plane (emerging agent payment protocols such as x402 and MPP), rather than replacing either.

AIF contributes three minimum artifacts — the **Action Envelope**, the **Accountability Escrow**, and the **Receipt protocol** — together with a capability algebra for authority, a structured reversibility descriptor, a tiered issuer market, and a framework-membership liability allocation. Identity binds to a *behavior commitment* and a *harness attestation* rather than to model weights,

so continuous fine-tuning does not churn identities or destroy reputation. Five nested conformance levels let adopters take the smallest useful subset first and incrementally upgrade.

The framework is explicitly complementary to existing standards and products: W3C DIDs and Verifiable Credentials, UCAN capability tokens, OpenID SSF / CAEP for revocation signals, transparency-log anchoring, and agent payment rails such as x402, MPP, ACP, and UCP. Its contribution is the composable accountability surface between these layers — the part the current landscape leaves underdefined.

Keywords: AI agents, decentralized identity, verifiable credentials, capability tokens, delegation, reversibility, accountability, agentic commerce, standards.

1. Introduction

The identity and authorization stack running on today’s internet was designed for a world in which a human sat behind a browser and a card. OAuth scopes, KYC on natural persons, card-network chargebacks, and court-adjudicated tort are the four load-bearing pieces of that stack. Each assumes a human principal whose identity is durable, whose authorization is discretionary per session, and whose mistakes can be adjudicated through legal forums that have several centuries of experience with human plaintiffs.

Autonomous software changes the assumptions in three ways that existing primitives do not accommodate gracefully.

Authorization is all-or-nothing. OAuth scopes are coarse, rarely time-bound, and almost never purpose-bound. An agent granted `scope=payments:write` can execute any payment the identity is entitled to execute, not just the one its user asked for. Session lengths are measured in hours or days, not seconds. Propagation of authority to sub-agents is ad hoc at best.

Accountability is ambiguous. When a KYC’d human signs in and clicks “pay,” liability is clear. When an agent places an order after a chain of delegations across models, operators, orchestration layers, and sub-agents, the question “who is responsible?” has no crisp cryptographic answer. Logs live in the losing party’s systems; the evidentiary chain for dispute is thin.

Reversibility is implicit. Card networks, ACH, marketplaces, and stablecoin rails each implement (or refuse to implement) reversal differently. Agents will transact across all of them. There is no cross-domain contract for what can be undone, by whom, under what evidence, and at what cost.

A fourth issue is unique to agents: they are **copyable, upgradable, and interchangeable** in ways that people and corporations are not. An “agent” is not a durable entity in the sense that a natural or legal person is. An identity framework that binds to a nominal label will be repeatedly surprised by behavior drift.

The rest of this paper sets out the design principles, architecture, and protocol primitives of a framework that addresses these gaps as a composable layer over existing identity, capability, and settlement stacks. It does not propose replacements for the W3C, IETF, Linux Foundation, or NIST work already in flight; it proposes the accountability surface that sits above them.

2. Design principles

Seven principles shape every design decision in the framework:

1. **Accountability is cryptographic, not contractual.** Every binding action is a signed statement from a traceable principal authority, carried in a canonical envelope. Disputes begin from receipts, not from logs maintained by the losing party.
 2. **Least authority, always attenuating.** A delegation can only narrow the permissions it received. Forwarded authority never exceeds forwarded-from authority.
 3. **Reversibility is a first-class property of every action.** Reversal semantics are declared at authorization time, checked at execution time, and enforceable after the fact by an arbiter.
 4. **Privacy is a design input.** Selective disclosure, identity escrow, and redactable receipts are first-class. A counterparty learns who would be liable, not necessarily who an end user is, in the happy path.
 5. **The ledger earns its keep.** Public blockchains are used where public verifiability, censorship resistance, or programmable settlement are essential; transparency logs and off-chain receipts are the default elsewhere.
 6. **Graceful degradation.** High-assurance features (multi-signature, identity escrow, bonded stake) are composable, not mandatory. The framework is useful for a four-euro coffee order and for a three-million-dollar B2B settlement.
 7. **Composable with what exists.** AIF is specified so that it wraps, rather than replaces, existing identity, capability, and payment protocols. Adopters contribute integration adapters, not re-implementations.
-

3. Architecture

AIF is organized as a **composable accountability layer**, not a stack. A layer, in this sense, is a set of protocols and roles that can be added to any existing identity-plus-settlement combination without requiring the underlying layers to be reimplemented.

The framework defines:

- Three **artifacts** — the Action Envelope, the Accountability Escrow role, and the Receipt / anchor protocol.
- One **algebra** — a small set of combinators over capability tokens for expressing authority.
- One **descriptor** — a structured reversibility type attached to every binding action.
- One **market structure** — a tiered issuer model with bonds, slashing, and monitor bounties.
- One **allocation** — a framework-membership liability allocation that applies between consenting participants.
- Five **conformance levels** (L0–L4) defining nested adoption stages.

The artifacts ride on top of existing identity and capability primitives. Agents already use W3C DIDs and Verifiable Credentials; they already carry UCAN or macaroon capabilities; they already settle on x402, MPP, card networks, or stablecoin rails. AIF adds the accountability envelope that wraps those calls, the escrow role that resolves liability without sacrificing pseudonymity, and the receipt protocol that preserves evidence for dispute.

Figure 1 shows the relationship:

Application (commerce, governance, fiduciary flows, ...)	
AIF – Composable Accountability Layer	
• Action Envelope • Accountability Escrow • Receipt / anchor protocol • Capability algebra • Reversibility descriptor	
Identity plane (DIDs, VCs, UCAN, SSF/CAEP, Sigstore)	Settlement plane (x402, MPP, ACP/UCP, cards, ACH, stablecoin rails, APIs)

Figure 1. AIF is not a vertical stack; it is a horizontal accountability surface that composes identity and settlement planes.

4. Identity: behavior commitments, not model hashes

An agent identity in AIF is a Decentralized Identifier (W3C DID) whose DID document carries, in addition to standard verification methods and service endpoints, three AIF-specific components:

Behavior commitment. A hash over the agent’s declared behavior contract: the allowed action classes, spending ceilings, refusal rules, circuit breakers, and disclosure obligations. The behavior contract is a machine-readable document; the commitment binds the identity to its content. A counterparty can request the full contract on demand.

Harness attestation. An attestation — ideally a Trusted Execution Environment (TEE) attestation such as AMD SEV-SNP, Intel TDX, or AWS Nitro Enclaves — of the runtime wrapper that enforces the behavior contract. The attestation covers the policy engine, the tool gate, and the capability verifier. It does not cover the underlying model.

Optional model provenance credential. A Verifiable Credential issued by the model vendor attesting that a given request ran against an unmodified release of their model. This is a credential, not a content hash; it is meaningful to the extent the vendor’s issuance process is trustworthy and the vendor is bonded.

The reason AIF does not bind identity to model weights is practical. Proprietary models do not publish weights, so a content hash is not third-party verifiable. Fine-tuning, RLHF patching, quantization, and continuous integration produce new weight blobs on a cadence of days; an identity that churns with every change destroys the reputation layer it is supposed to anchor. What counterparties care about is not which weights produced an action but what the agent promised to do and whether a bonded enforcement layer made that promise binding. Binding to promises and their enforcement — the behavior commitment and the harness attestation — answers the real question.

Agent identities in AIF are created by a **root principal** (a natural or legal person) or by an **operator** acting on a principal’s behalf. Agents may derive **session identities** — short-lived sub-identities bound to a specific task, scope, and time window — whose keys are signed by the parent agent identity. Session identities are the unit of rollback in most practical flows.

5. Authority: a capability algebra

AIF expresses authority as **capability tokens** in the tradition of UCAN, macaroons, and biscuits. A capability grants an ability over a resource, under caveats. Caveats are monotonic: they may be narrowed but not widened as tokens propagate. Any downstream holder can further attenuate a token but can never remove a caveat set upstream.

Real organizational authority is rarely linear, so AIF specifies a small algebra for combining capabilities:

- **AND**(*a*, *b*) — both authorities must co-sign for the action to bind.
- **OR**(*a*, *b*) — either authority suffices.
- **THRESHOLD**(*k*, [*a*₁, ..., *a*_{*n*}]) — any *k* of *n* authorities co-sign.
- **WITHIN**(*a*, *caveat*) — authority *a* narrowed by an additional caveat.

An action accompanied by a formula (for example **AND**(*cfo*, *legal*) for a high-value corporate wire, or **THRESHOLD**(2, [*user*, *operator_policy_engine*, *fraud_monitor*]) for a high-risk consumer transaction) is bound only when the formula evaluates to true against the signatures present on the envelope.

The algebra composes naturally with modern cryptographic primitives: Schnorr and BLS threshold signatures implement **THRESHOLD** efficiently; **AND** and **OR** are trivial conjunctions and disjunctions of verified signatures; **WITHIN** is the base case of capability attenuation. The algebra is what lets AIF handle joint principals, multi-tenant operators, conflicting delegators, and cross-organization hops without the fiction of a single linear chain.

6. The Action Envelope

Every binding action in AIF is wrapped in an **Action Envelope**, a canonical signed message whose structure is the centerpiece of the framework:

```
{
  action_id:      <uuid>,
  actor:          <agent_session_id>,
  authority:      <capability algebra formula with signatures>,
  action:         { <domain-specific payload> },
  reversibility:  { window, recoverable_value, requires_cooperation,
                  external_visibility, compensation_policy_ref },
  settlement:     { rail, amount?, escrow_ref?, idempotency_key },
  accountability: { escrow_trustee_id, dispute_forum, sla },
  receipt:        { log_endpoint, anchor_policy },
  timestamp, nonce, signature
}
```

The envelope is the unit of accountability. Its fields are:

- **actor** — the session identity executing the action.

- **authority** — the formula over capability tokens that authorizes the action, with the signatures that satisfy the formula.
- **action** — the domain-specific payload (invoke an API, sign a document, place an order, vote on a proposal).
- **reversibility** — a structured descriptor of how the action can be undone (see §7).
- **settlement** — the rail on which value moves, if any, plus an idempotency key.
- **accountability** — a reference to the Accountability Escrow trustee and the declared dispute forum (see §8).
- **receipt** — the transparency-log endpoint where the envelope is anchored.

The envelope is signed by the actor session key and by any additional signatures required by the **authority** formula. A verifier validates the envelope by (1) checking that the **authority** formula evaluates to true under the signatures, (2) verifying that the session key is valid and not revoked, (3) verifying that the behavior commitment of the underlying agent permits the **action**, (4) checking that the reversibility descriptor is consistent with policy for the counterparty, and (5) confirming receipt log inclusion.

An envelope without a valid **authority** is not a binding action. This is the cryptographic expression of principle 1.

7. Reversibility as a structured descriptor

AIF does not collapse reversibility into a single letter grade. Reversibility varies along at least four independent dimensions, each of which matters to counterparties and arbiters:

Window. How long a reversal is mechanically possible. A stablecoin escrow might release after 120 seconds; a goods-delivery might be reversible within a 30-day return policy; an irreversible transfer has a zero window.

Recoverable value. What fraction of the transferred value can be recovered on reversal, minus reversal costs. A refund-at-full returns 1.0; a partial restocking fee returns 0.85; a destroyed asset returns 0.

Cooperation requirement. Whether reversal can be executed unilaterally (by an escrow contract or idempotent API) or requires the counterparty’s cooperation.

External visibility. Whether third parties have observed the action, and whether their state can be rewound. A sent email cannot be unsent; a published document can be retracted but not erased from those who read it.

In addition, a **compensation policy reference** identifies the contract or policy that governs compensating action when true reversal is impossible: refund, republished correction, takedown, cash settlement, or a bespoke policy.

Counterparties and arbiters evaluate the descriptor against policy. Downgrading — claiming a lower reversibility than the action actually has — is forbidden. Upgrading — wrapping a high-risk action in an escrow that makes it reversible — is always permitted.

This approach produces more usable reasoning in the common hard cases. A shipped-and-returnable package and a published-and-retractable tweet are not the same “class”; they differ in cooperation requirement and external visibility in ways that matter for dispute. A four-euro coffee refund and

a million-dollar return-within-30-days are not the same class; they differ in window, recoverable value, and the cost of reversal. A typed descriptor distinguishes them.

8. The Accountability Escrow

AIF introduces a distinct role — the **Accountability Escrow trustee** — to resolve the tension between pseudonymity and liability.

A counterparty accepting an action from an agent needs to know who would be liable if things go wrong. But in most consumer flows, they do not have a legitimate interest in knowing the identity of the end user in the happy path. AIF resolves this by having every binding action reference a **trustee** who holds a sealed pointer to the root principal’s identity.

In the happy path, the counterparty sees:

- The agent’s DID and behavior commitment.
- The operator’s DID, tier, and reputation.
- The trustee’s DID, bond, and jurisdictional fit.
- The accountability seal — a cryptographic commitment to the root principal’s identity, resolvable only by the trustee.

The counterparty does not see who the end user is. If a dispute arises and a valid trigger is presented — for example, a fraud claim with evidence sufficient to meet the trustee’s unseal policy — the trustee unseals the pointer and discloses the root principal to the appropriate forum (an arbiter, a regulator, a court).

Trustees are a new regulated entity class with concrete requirements:

- Bonded, with slashing conditions for mis-disclosure or wrongful non-disclosure.
- Jurisdictionally competent — a trustee serves the jurisdictions its bond covers.
- Publicly listed with audited procedures for sealing, unsealing, and dispute review.
- Subject to monitor bounties for detecting policy violations.

Whether trustees best fit the existing money-transmitter, notary, transfer-agent, or bonded-agent regulatory frameworks is jurisdiction-dependent and is one of the open research questions (§15).

The Accountability Escrow is load-bearing in AIF. It is what lets the framework offer strong accountability without the privacy cost of universal PII disclosure, and it is what gives counterparties an ex ante answer to “who would I recover from?” without giving them an ex ante answer to “who is this person?”

9. Receipts and transparency

Every envelope emits a **Receipt** — an append-only record of the envelope’s authorization and execution, submitted to a **transparency log** that returns a Merkle inclusion proof. The log is modeled on Certificate Transparency and Sigstore’s Rekor: publicly monitorable, client-verifiable inclusion proofs in $O(\log n)$, no single-party-trusted operator.

Receipts are the primary evidentiary artifact for dispute. A party presenting a receipt with a valid inclusion proof establishes — without needing the opposing party’s cooperation — that a specific

envelope was bound at a specific time under a specific authority.

For higher-assurance flows, receipts are **anchored** to a public blockchain (EVM-compatible L2 by default). Anchoring commits the receipt’s Merkle root on-chain at a declared cadence, producing an immutable timestamp that neither party can later repudiate. Anchoring is selective, not universal; high-volume low-stakes actions remain off-chain, while regulated, high-value, or dispute-prone flows anchor on-chain.

Receipts include **redactable components**: fields containing natural-person data (PII, KYC references, sensitive credentials) are stored separately under a redaction key held by the trustee, while the receipt’s public portion carries only commitments. On a valid deletion request consistent with the applicable privacy regime (for example, GDPR Article 17), the redactable components can be tombstoned without invalidating the commitments the rest of the system depends on.

This selective-redaction pattern is the framework’s answer to the tension between durable public audit trails and the right to erasure. The durable public artifact is the commitment and the inclusion proof; the plaintext lives under the trustee and is subject to the same deletion obligations as any other personal data processor.

10. Credentials and issuer market structure

Agents, operators, and root principals present claims through **Verifiable Credentials** (W3C VC 2.0) at action time. Common credential classes:

- **KYC credential** on the root principal, issued by an accredited KYC provider.
- **Operator license** — e.g., “this operator is licensed as a payment facilitator in the EU.”
- **Model provenance** — issued by the model vendor.
- **Policy conformance** — issued by an auditor.
- **Financial limits** — issued by a bank or card network.
- **Reputation** — issued by counterparties and marketplaces.

Selective disclosure (BBS+ signatures, zk-proofs) is first-class where deployed, and the framework degrades gracefully to full-disclosure with trustee-mediated revelation where it is not.

Credentials are only as trustworthy as their issuers. In an open market, the lowest-diligence issuer wins price-sensitive business and drives out more careful issuers — a Gresham’s-law dynamic that has plagued prior credential ecosystems. AIF addresses this with three mechanisms:

Tiered accreditation. Issuers belong to publicly visible tiers (for example, I1 for regulated financial institutions, I2 for bonded but unregulated issuers, I3 for unbonded issuers). Verifiers set floors per action class. Tier is presentable alongside the credential.

Issuer bonds and slashing. Higher-tier issuers post bonds. Proven mis-issuance (for example, KYC credentials on sanctioned persons, or policy-conformance attestations on known-unsafe behavior) slashes the bond.

Monitor bounties. The framework standards body funds a standing bounty for third-party monitors who detect and prove mis-issuance. Bounties are paid from slashed bonds.

Credentials are short-lived by default (hours to weeks), with freshness checks via OpenID Shared Signals Framework (SSF) and Continuous Access Evaluation Profile (CAEP) endpoints. Stale

credentials are a production-identity failure mode that the framework refuses to tolerate.

11. Liability allocation

A protocol cannot bind a court. What AIF provides is a **framework-membership allocation** — an explicit contractual agreement, entered by all framework participants, that governs how losses are allocated among members. Non-members are unbound; regulators retain their own allocations (consumer credit, fiduciary duty, healthcare); plaintiffs retain their common-law theories. The allocation is not a tort preemption; it is a predictable default between consenting parties, enforceable via arbitration and by reference to membership agreements in court.

The membership allocation takes the shape of a waterfall:

Loss L

- |
- └─ Tranche 1: Operator first-loss (strict liability for platform defects)
- └─ Tranche 2: Reputation bond slash (on proven fault)
- └─ Tranche 3: Per-task escrow or transaction bond
- └─ Tranche 4: Insurance pool payout (framework-operated mutual)
- └─ Residual: Root principal, bounded by delegated scope

Two features matter. **Strict vs. fault-based attachment** is made explicit per tranche: a platform defect (a bug that broke session-key scoping) attaches strictly to the operator, while a user-directed mistake (the user authorized a bad payment) attaches to the root principal but recovers from insurance first. **Jurisdictional fit** is explicit: where regulators mandate specific allocations, the framework defers to them and the waterfall governs only the remainder.

The reason to codify the waterfall as a membership allocation rather than presenting it as a normative rule is honesty about what protocols can and cannot do. A protocol that clarifies, structures, and makes evidence reconstructable is doing real work; a protocol that pretends to displace tort law is not.

12. Conformance levels

AIF is deliberately adoptable in stages. Five nested conformance levels define the path:

Level 0 — Envelope and authority. Implementations produce and verify Action Envelopes with capability-algebra authority. This is the minimum interoperability bar. An L0-compliant agent can execute bound actions against any L0-compliant counterparty.

Level 1 — + Accountability Escrow. Implementations reference a trustee in every envelope; counterparties verify the trustee’s bond and jurisdictional fit. L1 enables pseudonymous consumer flows.

Level 2 — + Enforced reversibility. Implementations enforce the reversibility descriptor and execute compensation policies. L2 enables cross-rail rollback guarantees.

Level 3 — + Bonded issuers and anchored receipts. Implementations consume tier information, honor issuer bonds, and anchor high-value receipts on-chain. L3 enables high-value B2B

and regulated flows.

Level 4 — + Reputation and insurance pool. Implementations participate in reputation credential exchange and insurance-pool settlement. L4 enables consumer commerce at scale.

The levels are nested: every L_n implementation is also an $L_{(n-1)}$ implementation. A counterparty declares the minimum level it accepts; the action either meets it or is refused. This refusal, in practice, is what creates adoption pressure to advance through the levels.

An L0-only implementation is cheap enough to bolt onto any existing agent runtime today. An L4 deployment is a multi-year consortium project. AIF's adoption strategy depends on this gradient: begin where friction is lowest, let commercial pressure pull adopters upward.

13. Integration with the existing ecosystem

AIF does not work if it does not compose cleanly with the identity and settlement protocols already being built. This section documents the seams.

W3C DIDs and Verifiable Credentials. AIF consumes DIDs for identity and VCs for claims. Any DID method is acceptable; `did:web`, `did:key`, `did:ethr`, and `did:pkh` are straightforward. VC 2.0 with BBS+ signatures is supported for selective disclosure.

UCAN capability tokens. AIF's capability algebra is a small superset of UCAN semantics, interpreting a UCAN proof chain as a linear form of the algebra (**WITHIN** composition). UCANs are accepted as-is.

OpenID SSF / CAEP. Revocation and session-change signals consumed by AIF verifiers during envelope verification. This is the integration path demonstrated by ZeroID.

Microsoft Agent Governance Toolkit / Agent Mesh. AIF envelopes ride on the Inter-Agent Trust Protocol (IATP) transport; AIF's behavior commitment complements Agent Mesh's cryptographic identity.

x402 (Linux Foundation). AIF wraps x402 payment calls with the Action Envelope; the envelope's `settlement.rail` field selects x402, the idempotency key enforces the rollback triad, and the trustee reference carries across the call.

Machine Payments Protocol (MPP, Stripe / Paradigm). Similar integration: MPP provides session-preloaded fund management, AIF provides the per-action accountability envelope.

OpenAI Agentic Commerce Protocol (ACP) and Google Universal Commerce Protocol (UCP). These are commerce-journey protocols above the settlement layer. AIF envelopes wrap the commerce actions, carrying the capability chain and reversibility descriptor through the journey.

Google A2A and Anthropic MCP. These are agent-to-agent and agent-to-tool transport protocols. AIF defines envelope headers that ride on either transport without modification.

Sigstore / Rekor transparency logs. The reference receipt log is Sigstore-compatible; inclusion-proof verification reuses existing client libraries.

TEE attestations. AMD SEV-SNP, Intel TDX, and AWS Nitro Enclave attestations satisfy the harness-attestation requirement for the behavior-commitment enforcement layer.

The framework ships integration adapters for each of these as part of its reference implementation. An adopter picks the combination that matches their stack and inherits the rest of AIF’s semantics above.

14. Illustrative use cases

Four scenarios to demonstrate the shape of the framework in practice.

Personal shopping agent. A consumer delegates a €400 weekly grocery budget to an agent. The agent’s session identity carries a UCAN chain from the user, narrowed to approved merchants and a per-item cap. Each purchase emits an envelope with a reversibility window of 120 seconds and settlement via stablecoin escrow. A bonded trustee holds the accountability seal for the root principal. Merchant accepts envelopes at L1 conformance. User-side cancellation within the window triggers unilateral escrow refund; merchant-side non-confirmation expires the escrow. Total consumer experience is indistinguishable from a modern card tap. The accountability surface is what makes this tap safe for an autonomous buyer.

Enterprise procurement. A corporate buyer’s agent negotiates a supply contract. The action envelope’s authority field carries an `AND(cfo, legal_counsel)` formula, and the reversibility descriptor declares a 30-day review window with a compensation policy pointing to a signed master services agreement. Receipts anchor on-chain for auditability. Both parties operate at L3 conformance, with bonded issuers supplying credentials on operator licensing and model provenance. A dispute invokes the declared arbitration forum, which evaluates envelopes and receipts without needing either party’s internal logs.

DAO governance delegation. A token-holder delegates voting authority to an agent for a specific proposal season. The delegation is a UCAN chain with purpose-bound caveats (proposals within category X, positions aligned with declared preferences). Votes carry envelopes at L2 conformance; the voting contract verifies the delegation chain and the envelope’s reversibility descriptor (a reversible-within-quorum window). Mid-season revocation is propagated via SSF/CAEP; the voting contract consults the revocation signal before counting votes.

Regulated fiduciary rebalancing. A robo-advisory agent rebalances a retail portfolio under SEC-regulated fiduciary duty. Every rebalance emits an L4 envelope — authority is `THRESHOLD(2, [user, advisor_policy, suitability_check])`, reversibility is a narrow class-D window with a compensation policy for good-faith execution of a flawed trade, receipts anchor on a regulated permissioned ledger, and a mutual insurance pool provides first-loss coverage for suitability-failure claims. The framework provides the evidentiary trail; SEC enforcement retains its existing authority.

15. Threat model

The framework’s threats divide into adversarial use and adversarial adoption.

Stolen session key. Short session-key lifetimes, mandatory revocation checks at envelope verification, and class-B rollback of in-window actions contain the blast radius. Receipts permit post-compromise forensic reconstruction.

Malicious operator. Operator bonds plus transparency-log monitoring detect policy bypass.

Credential revocation by issuers propagates via SSF/CAEP. Root principals retain the right to switch operators and carry their receipt history.

Collusive operator and counterparty. Independent monitors — funded by bounty from slashed bonds — audit the transparency log. Insurance-pool claims proceed on arbiter finding without requiring operator cooperation.

Credential-issuance fraud. Issuer bonds, public revocation registries, and monitor bounties. Higher-tier issuers face stricter audits.

Prompt-injection and agent hijacking. Capability attenuation limits blast radius. High-stakes envelopes require additional signatures in the **authority** formula, including out-of-band human confirmation. Anomaly-based circuit breakers operate independently of the model.

Clone attacks. Harness attestation binds the enforcing layer to hardware-rooted identity. A clone produced outside attested hardware is a different DID with no reputation history.

Sybil reputation. Reputation anchors to bonded, KYC-backed root principals; new agent identities start from a low prior; bonding makes Sybil attacks economically unprofitable.

Privacy leakage via receipts. Receipts contain commitments, not plaintext; the accountability seal is unsealed only on valid dispute trigger; selective redaction honors deletion obligations.

Adversarial adoption. The framework anticipates adoption threats as well as use-time threats: capture of the standards body by a dominant vendor, Gresham-dynamic races to the bottom on issuer diligence, shell-company root principals with no recoverable assets, and jurisdictional arbitrage. Open governance, tiered accreditation, insurer underwriting that prices shell exposure, and cross-jurisdiction trustee agreements are the mitigations.

Agent-to-agent collusion. Capability scoping does not stop rational coordination that happens to harm third parties. The framework is compatible with antitrust-style external oversight; it supplies the audit trail, it does not replace the oversight.

16. Open research questions

Several questions require research, not just engineering, before the framework can reach L3 and L4 maturity.

Post-hoc behavior-commitment verification. How does a verifier confirm, after the fact, that the agent honored its behavior contract without replaying the model? Candidate approaches include structured reasoning traces, streaming anomaly detection on action sequences, and TEE-attested policy enforcement. None are yet production-mature.

Metadata-private transparency logs. Log contents are commitments, but timing, frequency, and counterparty patterns leak information. Differential-privacy-style mixing, batched submission, and log sharding are candidate techniques. The design space is under-explored.

Reversibility descriptor standardization. Cross-industry definitions for each field, with reference mappings from existing rails (card networks, ACH, Swift, stablecoin escrow, REST APIs). This is a working-group problem, not a research problem, but it requires industry convening that does not yet exist.

Reputation half-life calibration. What decay function keeps reputation signals meaningful without creating permanent personal records? This is partly an empirical question once adoption data exists.

Trustee regulation. Under which existing framework (money transmitter, notary public, transfer agent, bonded agent, common carrier) does the Accountability Escrow best fit? The answer differs by jurisdiction and likely requires new regulatory guidance in several of them.

Agent-to-agent collusion detection. Distinguishing emergent-but-innocent coordination from deliberate collusion is a machine-learning problem with few solved analogs in existing markets.

Cross-jurisdiction dispute routing. A protocol-level way to declare forum and choice-of-law that is actually respected by courts in multiple jurisdictions. This is a legal-harmonization question as much as a technical one.

17. Related work

Standards bodies and initiatives. The NIST Center for AI Standards and Innovation (CAISI) launched an AI Agent Standards Initiative in February 2026, including agent authentication and identity infrastructure as core pillars. The Linux Foundation’s Agentic AI Foundation (AAIF) is the umbrella for several of the emerging protocols. AGNTCY has emerged as a complementary networking and security layer.

Open-source identity platforms. Microsoft’s Agent Governance Toolkit (April 2026, MIT-licensed) implements cryptographic agent identity on DIDs with Ed25519 and an Inter-Agent Trust Protocol. ZeroID (April 2026) integrates OpenID SSF and CAEP for real-time session revocation in a purpose-built agent identity platform.

Academic work. Rittenbruch et al., *AI Agents with Decentralized Identifiers and Verifiable Credentials* (arXiv 2511.02841), propose ledger-anchored W3C DIDs with third-party VCs and DIF presentation proofs. *A Novel Zero-Trust Identity Framework for Agentic AI* (arXiv 2505.19301) pushes zero-trust and fine-grained access control. *did:wba* offers a web-based DID method for agent networks. An *Agent Identity Protocol (AIP) for Verifiable Delegation Across MCP and A2A* addresses delegation interoperability.

Capability tokens. The UCAN Working Group’s specification is the most mature capability-token standard with production adopters (Storacha / Web3.Storage). Macaroons and biscuits remain the formal precursors.

Agent payment protocols. x402 (Linux Foundation, Google/OpenAI/Circle, April 2026) and the Machine Payments Protocol (Stripe/Paradigm, March 2026) are the leading candidates for the neutral agent payment rail. OpenAI’s Agentic Commerce Protocol (ACP) and Google’s Universal Commerce Protocol (UCP) sit above at the commerce-workflow layer. Anthropic’s Model Context Protocol (MCP) and Google’s A2A handle agent-to-tool and agent-to-agent transport.

Transparency and signing. Certificate Transparency, Sigstore / Rekor, and the Go module checksum database are the production analogs the receipt protocol inherits from. The Ethereum Attestation Service (EAS) provides on-chain attestation primitives compatible with AIF’s anchoring layer.

AIF’s contribution in this landscape is the accountability envelope, the escrow role, and the receipt protocol — the glue that lets the other layers compose into a binding, reversible, dispute-ready whole.

18. Conclusion

The agentic economy is being built right now. The payment rails are being standardized, the identity primitives are being productized, and the governance toolkits are shipping. What remains unshipped is the accountability layer that turns these into a system a person or a court can trust with binding economic actions.

The Agent Identity Framework contributes that layer. It is deliberately composable with the protocols already in motion. It binds identity to promises and their enforcement, not to inference weights. It treats authority as an algebra, reversibility as a typed descriptor, and liability as an explicit membership allocation rather than a pretended tort theory. It defines three minimum artifacts — the Action Envelope, the Accountability Escrow, and the Receipt protocol — that adopters can implement incrementally, beginning at conformance level 0.

The framework is offered as a draft for public comment and as input to the standards processes now in motion at NIST CAISI, the Linux Foundation AAIF, the W3C Credentials Community Group, the IETF SPICE working group, and the UCAN Working Group. Reference implementations, conformance tests, and pilot documentation will accompany subsequent versions.

The purpose of the framework is not to win a standards war. It is to make the agentic economy safe enough to adopt, transparent enough to audit, and reversible enough to trust.

References and further reading

Standards and working groups.

- NIST Center for AI Standards and Innovation (CAISI), *AI Agent Standards Initiative*, February 2026. <https://www.nist.gov/caisi/ai-agent-standards-initiative>
- Linux Foundation, *Agentic AI Foundation (AAIF)*. <https://www.solo.io/blog/aaif-announce-ment-agentgateway>
- W3C, *Decentralized Identifiers (DIDs) v1.0*. W3C Recommendation.
- W3C, *Verifiable Credentials Data Model v2.0*.
- UCAN Working Group, *User Controlled Authorization Networks specification*. <https://github.com/ucan-wg/spec>
- OpenID Foundation, *Shared Signals Framework (SSF) and Continuous Access Evaluation Profile (CAEP)*.
- IETF, *Secure Patterns for Internet Credentials (SPICE)* working group.

Open-source platforms and protocols.

- Microsoft, *Agent Governance Toolkit*, April 2026. <https://opensource.microsoft.com/blog/2026/04/02/introducing-the-agent-governance-toolkit-open-source-runtime-security-for-ai-agents/>
- ZeroID, *Open-source identity platform for autonomous AI agents*, April 2026.

- x402 agent payment protocol, Linux Foundation, April 2026.
- Stripe & Paradigm, *Machine Payments Protocol (MPP)*, March 2026.
- OpenAI, *Agentic Commerce Protocol (ACP)*.
- Google, *Universal Commerce Protocol (UCP)* and *Agent-to-Agent (A2A)*.
- Anthropic, *Model Context Protocol (MCP)*.
- Sigstore / Rekor transparency log. <https://www.sigstore.dev>
- Ethereum Attestation Service (EAS).

Academic work.

- Rittenbruch et al., *AI Agents with Decentralized Identifiers and Verifiable Credentials*, arXiv:2511.02841.
- *A Novel Zero-Trust Identity Framework for Agentic AI: Decentralized Authentication and Fine-Grained Access Control*, arXiv:2505.19301.
- *did:wba: A Web-based Decentralized Identifier*.
- *Agent Identity Protocol (AIP) for Verifiable Delegation Across MCP and A2A*, arXiv:2603.24775.

Foundational cryptography and attestation.

- Birgisson, A. et al., *Macaroons: Cookies with Contextual Caveats*, 2014.
- AMD SEV-SNP, Intel TDX, AWS Nitro Enclaves attestation specifications.
- BBS+ signature scheme for selective disclosure.

End of paper, v1.0. Comments and contributions welcome. The author can be reached at the LinkedIn profile on the title page.